

**BỘ KHOA HỌC VÀ CÔNG NGHỆ
HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG**



BÁO CÁO ĐỒ ÁN MÔN HỌC

ĐỀ TÀI:

**PROJECT #103. SHAMIR'S SECRET SHARING FOR DB
CREDENTIALS**

DESIGN DOCUMENT

Môn học: Cơ Sở Dữ Liệu Phân Tán

Giảng viên: Lê Hà Thanh

Thực hiện bởi sinh viên: Bùi Kiếm Khoa N23DCCN029 D23CQCN01-N

TP.HCM, tháng 05 /2026

Mục Lục

1. Architecture Overview	3
2. Cryptographic Design	3
2.1 Threat Model	3
2.2 Secret Generation & Polynomial Construction.....	4
2.2.1 Trường hợp có đủ 3 share trở lên	5
2.2.2 Trường hợp chỉ có 1 hoặc 2 share	5
2.3. AES256CBC Encryption / Decryption	6
3. Design Decisions & Justification	6
4. Failure Scenario Map	7
5. Theoretical Proof of the (3, 5) Threshold	7

DESIGN DOCUMENT

Project #103: Shamir's Secret Sharing for DB Credentials

1. Architecture Overview

Hệ thống gồm ba lớp logic chính: lớp lõi mật mã (Python), lớp phân tán các mảnh khóa (5 máy chủ Node.js), và lớp điều khiển/giao diện người dùng GUI (Python Tkinter). Sơ đồ bên dưới minh họa luồng dữ liệu giữa các thành phần trong hệ thống.

Layer	Modules	Responsibility
GUI / Control	app.py	Tương tác người dùng, quản lý trạng thái hoạt động của node và hiển thị tiến trình
Crypto Core	share_generator.py utils.py encrypt_database.py decrypt_database.py	Quá trình sinh khóa, tính toán đa thức, nội suy Lagrange và mã hóa/giải mã bằng AES256CBC
Node Layer	node1-node5 / server.js	HTTP REST endpoints: /share (GET), /health (GET), /shutdown (GET)
Storage	shares/, nodes/, database/	JSON shares, encrypted .enc binary, recovered JSON output, recovery_report.txt

2. Cryptographic Design

2.1 Threat Model

Security Objective

Mục tiêu của hệ thống The Vault là bảo vệ khóa AES-256 dùng để mã hóa cơ sở dữ liệu phân tán. Hệ thống phải đảm bảo rằng khóa bí mật chỉ có thể được khôi phục khi có ít nhất $t = 3$ trong tổng số $n = 5$ shares hợp lệ. Đồng thời, việc chiếm quyền kiểm soát một phần hệ thống không được làm lộ khóa bí mật hoặc nội dung cơ sở dữ liệu.

Adversary Capabilities

Kẻ tấn công được giả định có thể:

- Đọc hoặc sao chép trực tiếp tệp database.enc.

- Xâm nhập tối đa 2 node và lấy các share được lưu trong share.json.

- Làm một hoặc nhiều node ngừng hoạt động (Denial of Service).

- Quan sát lưu lượng HTTP giữa các thành phần trong môi trường demo.

- Sở hữu toàn bộ mã nguồn của hệ thống (Kerckhoffs's Principle).

Kẻ tấn công không được giả định có khả năng:

- Đồng thời chiếm được từ 3 share trở lên.

- Phá vỡ thuật toán AES-256 bằng tấn công mật mã học.

- Giải được bài toán brute-force trên không gian khóa 2^{256} trong thời gian khả thi.

Security Assumptions

Hệ thống dựa trên các giả định sau:

1. AES-256 vẫn an toàn trước các tấn công mật mã học hiện nay.
2. Bộ sinh số ngẫu nhiên mật mã (secrets.randbits) tạo ra khóa và hệ số đa thức không thể dự đoán.
3. Số nguyên tố

$$p = 2^{257} - 93$$

đủ lớn để biểu diễn toàn bộ khóa AES-256 và thực hiện các phép toán trên trường hữu hạn một cách chính xác.

4. Mỗi node chỉ lưu trữ đúng một share và không có node nào lưu toàn bộ khóa bí mật.

Security Guarantees

Dưới các giả định trên, hệ thống cung cấp các đảm bảo sau:

Threshold Security: Bất kỳ tập hợp nào có ít hơn 3 shares không thể xác định duy nhất khóa bí mật.

Perfect Secrecy: Với 1 hoặc 2 shares, mọi giá trị bí mật trong trường $GF(p)$ đều có xác suất như nhau; kẻ tấn công không thu được thêm thông tin nào về khóa thật.

Confidentiality: Dữ liệu trong database.enc không thể đọc được nếu không khôi phục đúng khóa AES-256.

Fault Tolerance: Hệ thống vẫn hoạt động bình thường khi tối đa 2 node bị lỗi hoặc ngoại tuyến.

No Single Point of Failure: Không node đơn lẻ nào chứa đủ thông tin để khôi phục khóa bí mật.

Demonstrated Attacks

Để xác minh mô hình đe dọa, hệ thống triển khai chế độ **Hacker Mode** mô phỏng các cuộc tấn công thực tế:

1. Khôi phục khóa bằng 2 shares.
2. Đánh cắp trực tiếp tệp database.enc.
3. Brute-force khóa từ một share.
4. Giải mã cơ sở dữ liệu bằng khóa AES ngẫu nhiên.

Tất cả các kịch bản trên đều thất bại trong quá trình thực nghiệm, qua đó xác nhận rằng cơ chế Shamir (3,5) bảo vệ thành công khóa bí mật trước các mối đe dọa được mô hình hóa.

2.2 Secret Generation & Polynomial Construction

Cho khóa bí mật s là khóa AES256 được sinh ngẫu nhiên bằng bộ sinh số ngẫu nhiên mật mã của hệ điều hành (OS CSPRNG (secrets.randbits(256))). Hệ thống xây dựng một đa thức bậc hai trên trường hữu hạn $GF(p)$:

$$f(x) = s + a_1x + a_2x^2(\text{mod } p)$$

Trong đó:

$s = f(0)$ là khóa bí mật cần bảo vệ

a_1, a_2 là các hệ số ngẫu nhiên

$p = 2^{257} - 93$ là số nguyên tố lớn hơn mọi giá trị 256bit

Do đa thức có bậc 2, nên theo lý thuyết nội suy đa thức, cần tối thiểu 3 điểm khác nhau để xác định duy nhất đa thức này.

Các share được tạo dưới dạng:

$$(i, f(i) \text{ mod } p), \quad i \in \{1, 2, 3, 4, 5\}$$

Mỗi share được lưu riêng biệt tại một node độc lập và được cung cấp thông qua HTTP endpoint. Vì mỗi node chỉ nắm giữ một điểm trên đa thức nên không node nào có thể tự phục hồi khóa bí mật.

2.2.1 Trường hợp có đủ 3 share trở lên

Khi hệ thống thu thập được ít nhất 3 share hợp lệ từ các node đang hoạt động, môđun recovery sẽ sử dụng nội suy Lagrange để tái tạo đa thức và tính lại:

$$s = f(0)$$

Công thức nội suy:

$$s = \sum_{j=1}^k y_j \cdot L_j(0) \pmod{p}$$

với:

$$L_j(0) = \prod_{m \neq j} \frac{-x_m}{x_j - x_m} \pmod{p}$$

Do mọi phép toán đều được thực hiện trên trường hữu hạn $GF(p)$, việc khôi phục khóa là chính xác tuyệt đối ở mức bitlevel.

Trong quá trình thực nghiệm:

- hệ thống khôi phục đúng khóa AES gốc,
- file database.enc được giải mã thành công,
- nội dung JSON sau giải mã trùng khớp với dữ liệu ban đầu.

Điều này chứng minh rằng:

$$k \geq t = 3 \Rightarrow \text{khôi phục bí mật thành công}$$

2.2.2 Trường hợp chỉ có 1 hoặc 2 share

Khi số lượng share nhỏ hơn ngưỡng $t = 3$, hệ thống vẫn có thể thực hiện phép nội suy toán học, tuy nhiên kết quả thu được không còn là đa thức gốc.

Ví dụ:

- với 2 điểm, tồn tại vô số đa thức bậc hai đi qua hai điểm đó,
- mỗi đa thức sẽ cho một giá trị $f(0)$ khác nhau,
- do đó khóa được “khôi phục” thực chất chỉ là một giá trị ngẫu nhiên trong trường hữu hạn.

Nói cách khác:

$$k < t \Rightarrow \text{không đủ thông tin để xác định duy nhất } s$$

Trong hệ thống demo, recovery module vẫn cố gắng nội suy bằng số share hiện có, kết quả tạo ra một “fake secret”, khóa sai này được dùng để giải mã AES, file giải mã thu được chứa dữ liệu lỗi hoặc gibberish.

Việc cố tình cho phép giải mã bằng khóa sai nhằm minh họa trực quan rằng hệ thống vẫn có thể thực hiện thao tác giải mã ở mức kỹ thuật, nhưng dữ liệu thu được hoàn toàn vô nghĩa nếu khóa không chính xác, qua đó chứng minh tính bảo mật của cơ chế threshold.

Điều này thể hiện đúng tính chất lý thuyết của Shamir Secret Sharing: Bất kỳ tập share nào có kích thước nhỏ hơn ngưỡng t đều không cung cấp đủ thông tin để suy ra khóa bí mật gốc.

2.3. AES256CBC Encryption / Decryption

Khóa chính (master key) s được tuần tự hóa (serialize) thành một số nguyên 32 byte theo dạng **bigendian** và được sử dụng trực tiếp làm khóa AES. Cơ sở dữ liệu được mã hóa với một vector khởi tạo (IV) ngẫu nhiên mới, và IV này được thêm (prepend) vào đầu tệp ciphertext. Khi giải mã, hệ thống đọc IV từ 16 byte đầu tiên, sau đó dùng phần còn lại để giải mã bằng chế độ **AES.MODE_CBC** của PyCryptodome. Quá trình loại bỏ padding PKCS7 được thực hiện; nếu việc unpadding thất bại thì đó được xem là một tín hiệu mật mã cho thấy khóa không đúng.

Quan trọng Demo “Gibberish”: Khi có ít hơn 3 node hoạt động, hệ thống cố ý tiếp tục quá trình giải mã bằng một khóa sai. Bước loại bỏ padding (unpadding) sẽ thất bại, và các byte sau giải mã (trông như dữ liệu nhị phân ngẫu nhiên) sẽ được lưu thành file database_decrypted.json. Khi mở file này, nội dung hiển thị hoàn toàn không thể đọc được (gibberish), điều này trực quan chứng minh rằng nếu không có đủ ngưỡng $t = 3$ shares, dữ liệu mã hóa được bảo vệ theo nghĩa thông tin (informationtheoretically secure).

3. Design Decisions & Justification

Decision	Choice Made	Justification
Finite Field	$GF(2^{257} - 93)$	Số nguyên tố (prime) lớn hơn 2^{256} , đảm bảo rằng secret 256bit có thể được biểu diễn đầy đủ mà không xảy ra hiện tượng tràn (wraparound). Phân phối đều (uniform distribution) được giữ nguyên (Chương 3 - các thuộc tính phân phối dữ liệu).
Threshold (t, n)	$t = 3, n = 5$	Hệ thống chịu được tối đa 2 node đồng thời bị lỗi nhưng vẫn cho phép khôi phục dữ liệu - tương tự như các đánh đổi về tính sẵn sàng trong mô hình quorumbased (độ tin cậy / reliability).
Transport	HTTP REST (stateless)	Thiết kế node không trạng thái (stateless) phù hợp với nguyên tắc siteautonomy: mỗi node hoạt động độc lập và không yêu cầu cơ chế giao tiếp hay đồng bộ hóa phức tạp giữa các node.

AES Mode	AES256CBC + random IV	Chế độ CBC với IV mới (fresh IV) đảm bảo tính không phân biệt được của bản mã (ciphertext indistinguishability). IV là giá trị công khai (được gắn ở đầu file), nhưng tính ngẫu nhiên của nó giúp ngăn chặn các tấn công dựa trên bản rõ đã biết (knownplaintext attacks) đối với tệp cơ sở dữ liệu.
original_key.txt	Chỉ được lưu lại phục vụ mục đích demo.	Trong môi trường sản xuất, khóa không bao giờ được lưu trữ sau khi đã được chia nhỏ — tệp này chỉ là một thành phần minh họa (demo artifact), dùng để hỗ trợ việc xác minh tự động (so sánh theo từng byte) trong quá trình quay màn hình trình diễn. Trong triển khai thực tế, giá trị bí mật s sẽ được xóa khỏi bộ nhớ ngay lập tức sau khi quá trình tạo các share hoàn tất.

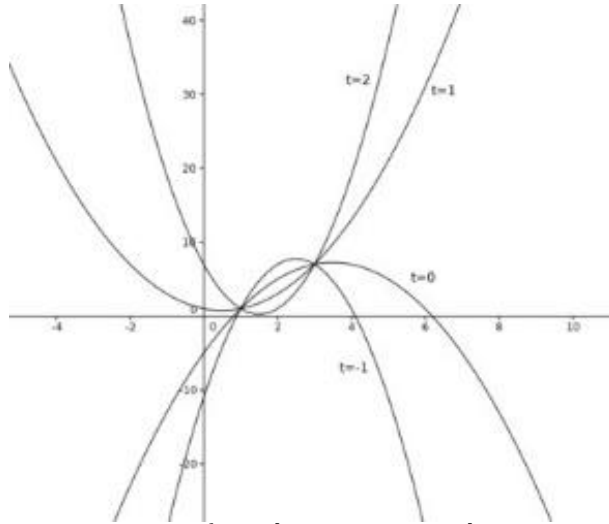
4. Failure Scenario Map

Nodes Online	Shares Available	Recovery Result	Database Output
5 / 5	5	CORRECT SECRET	Valid JSON đọc được
4 / 5	4	CORRECT SECRET	Valid JSON đọc được
3 / 5	3 (ngưỡng)	CORRECT SECRET	Valid JSON đọc được
2 / 5	2 (dưới ngưỡng)	WRONG KEY	GIBBERISH unpadding lỗi, raw bytes được lưu
1 / 5	1 (dưới ngưỡng)	WRONG KEY	GIBBERISH unpadding lỗi, raw bytes được lưu
0 / 5	0	RECOVERY FAILED	Quá trình giải mã không được thực thi

5. Theoretical Proof of the (3, 5) Threshold

Vì sao 3 shares là đủ

Một đa thức bậc d được xác định duy nhất bởi $d + 1$ điểm. Với ngưỡng $t = 3$, ta sử dụng một đa thức bậc 2. Khi có bất kỳ 3 điểm khác nhau trong trường hữu hạn $GF(p)$, công thức nội suy Lagrange sẽ dựng được duy nhất một đa thức bậc ≤ 2 sao cho giá trị tại $x = 0$ chính là bí mật s .



Hình 1: Từ hai điểm cố định có vô số đa thức bậc 2 đi qua

Điều này được đảm bảo bởi Định lý Unisolvence (Unisolvence Theorem).

Định lý Unisolvence (Unisolvence Theorem)

Trong đại số và nội suy đa thức, **định lý Unisolvence** phát biểu rằng:

Cho $n + 1$ điểm phân biệt $(x_0, y_0), (x_1, y_1), \dots, (x_n, y_n)$ với các giá trị x_i đôi một khác nhau, thì tồn tại duy nhất một đa thức $P(x)$ có bậc không vượt quá n sao cho:

$$P(x_i) = y_i \forall i = 0, 1, \dots, n$$

Nói cách khác, một đa thức bậc n được xác định duy nhất bởi $n + 1$ điểm phân biệt.

Trong bối cảnh **Shamir's Secret Sharing**, định lý này đảm bảo rằng với t điểm (shares), ta có thể duy nhất khôi phục lại đa thức bậc $t - 1$, và do đó suy ra giá trị bí mật tại $x = 0$.

Vì sao 2 shares không tiết lộ thông tin gì

Với chỉ 2 điểm (x_1, y_1) và (x_2, y_2) , tồn tại vô số đa thức bậc 2 đi qua cả hai điểm này tương ứng với mỗi giá trị hằng số khác nhau $s' \in GF(p)$. Nói cách khác, ta có thể “ghép” hai điểm đã biết với bất kỳ giá trị bí mật giả định nào và vẫn dựng được một đa thức hợp lệ.

Lược đồ Shamir đạt được độ **An toàn theo nghĩa thông tin (Perfect Secrecy)** theo lý thuyết Entropy của Shannon. Đối với đa thức bậc 2 (ngưỡng $t=3$), khi kẻ tấn công chỉ có 2 điểm, thì với bất kỳ một giá trị bí mật s' giả định nào trong trường hữu hạn $GF(p)$, chúng ta đều dựng được một đa thức hợp lệ đi qua 2 điểm đó. Nói cách khác, mọi giá trị bí mật đều khả dĩ và có xác suất đúng đồng đều là $1/p$. Việc sở hữu 2 mảnh khóa không làm giảm entropy (độ bất định) của hệ thống, xác suất hậu nghiệm bằng đúng xác suất tiên nghiệm. Do đó, kẻ tấn công hoàn toàn không có thêm bất kỳ thông tin nào để thu hẹp phạm vi tìm kiếm, dù chúng có dùng siêu máy tính để giải toán đi chăng nữa.

Do đó, kẻ tấn công chỉ có 2 shares sẽ không thu được thông tin nào về giá trị thật của s ; mọi giá trị có thể của bí mật đều tương thích hoàn toàn với dữ liệu quan sát được.